

Vendor Access Policy – Third Party Security

Effective Date: October 1, 2024

Owner: Information Security Team

1. Scope

1.1 This policy applies to all third parties – including vendors, consultants, contractors, auditors, and temporary staff – who require access to Company systems, networks, facilities, or data.

1.2 The policy does not apply to access granted to full-time employees, though contractors who are paid via a staffing agency are considered vendors for purposes of this policy.

2. Pre-Access Requirements

2.1 Before any access is granted, the vendor must sign a Data Processing Agreement (DPA) that incorporates the Company's standard data protection clauses, including confidentiality obligations, data breach notification requirements, and audit rights.

2.2 For vendors who will access production data (customer data or sensitive internal data), the DPA must also include indemnification provisions and evidence of SOC2 Type II or ISO 27001 certification.

2.3 A Vendor Security Assessment must be completed by InfoSec for any vendor with access to systems that contain customer or financial data. The assessment includes review of the vendor's security policies, penetration test results, and employee background check practices.

3. Types of Access and Restrictions

3.1 Access to production data – including live customer databases, production servers, and unredacted logs – is prohibited for all vendors. Only staging environments, anonymized data sets, or synthetic data may be used for development, testing, or support purposes.

3.2 Vendors requiring access to source code repositories (GitHub, GitLab) may be granted read-only access to specific repositories. Write access requires approval from the Engineering Director and a signed IP assignment agreement.

3.3 Administrative or privileged access (root, sudo, admin consoles) will not be granted to any vendor under any circumstances. Vendor support personnel must work alongside a Company employee with administrative privileges when such access is required.

4. Request and Approval Process

4.1 A vendor access request must be submitted via the Vendor Portal at vendor.company.com. The request must include: vendor name, employee name who will receive access, business justification, required systems and permissions, start date, and end date.

4.2 The request must be approved by both:

- a) The vendor sponsor (a Company employee responsible for the vendor relationship), and
- b) The Information Security Team (or IT for non-technical access such as badge to a meeting room).

4.3 Approval is valid for a maximum of 90 days. For access needed beyond 90 days, a renewal request must be submitted at least 15 days before expiration. Renewals require re-approval from both the sponsor and InfoSec.

5. Offboarding and Expiration

5.1 Vendor accounts will be automatically disabled on their expiration date. No grace period is provided.

5.2 When a vendor engagement ends, the vendor sponsor must submit an offboarding request within 24 hours to ensure all accounts, VPN certificates, and physical badges are revoked.

5.3 The vendor must certify in writing within 5 business days that all Company data in their possession has been deleted or returned. The certification must include a signed affidavit.

6. Breach Reporting and Consequences

6.1 If a vendor experiences a data breach that may affect Company data, the vendor must notify security@company.com within 48 hours of discovery. The notice must include the nature of the breach, data types involved, number of records, and remediation steps.

6.2 Failure to report a breach within the required timeframe will result in immediate termination of the vendor contract and may result in legal action for damages.

6.3 Vendors found to have violated this policy (e.g., sharing credentials, accessing data beyond scope) will have all access revoked and may be placed on a restricted vendor list, preventing future contracts with the Company.